

PROVE IT OR LOSE IT

# THE CMMC LEVEL 2 SURVIVAL GUIDE

Everything a small IT or cybersecurity federal contractor needs to understand, implement, and **prove** the 110 security requirements of NIST SP 800-171 — for the self-assessment, and for the day a C3PAO assessor walks through your door.

PREPARED BY CHRIS JUDKINS · companion to CMMC Vault · [github.com/CJud25/CMMCVault](https://github.com/CJud25/CMMCVault)

**110**

REQUIREMENTS

**14**

FAMILIES

**320**

ASSESSMENT  
OBJECTIVES

**88**

MINIMUM  
CONDITIONAL SCORE

**180**

DAYS TO CLOSE A  
POA&M

YOU DON'T GET CREDIT FOR BEING SAFE — ONLY FOR BEING ABLE TO  
SHOW IT

---

A learning & preparation aid — not legal advice, not an official DoD publication, and it confers no CMMC status. Sources: 32 CFR Part 170 · NIST SP 800-171 Rev 2 / 800-171A · CMMC L2 Guides v2.13

# HOW TO USE THIS GUIDE

CMMC feels like a wall of federal prose. It isn't. It is one idea repeated 110 times: **decide a rule, follow the rule, and keep proof that the rule is really happening.** This guide walks that idea down a single trail — eight waypoints from "what even is CUI?" to "the assessor just left, now what?"

## WHO EACH PART IS FOR

| IF YOU ARE...                        | READ...                                                                                                                                                                  |
|--------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| The owner / executive                | The 60-second briefing, the journey map, Waypoints 5–7 (scoring, POA&M, SPRS), and "Ten ways teams get hurt." You sign the affirmation — understand what you're signing. |
| The IT / security lead               | Everything. Waypoint 4 (the 14 families) is your build list; the evidence chapter is your proof standard.                                                                |
| The office manager / HR / facilities | Waypoint 4 families PS, PE, AT, and MP — people, doors, training, and paper. Plus the employee card at the back.                                                         |
| Every employee                       | The one-page employee card near the end. Six rules. That's it — post it in the break room.                                                                               |

## THE THREE BOXES TO WATCH FOR

■ TRAIL MARKER

Orientation: what this step is and why it exists. Read these and you'll always know where you are.

▲ WATCH OUT

A hazard that regularly hurts small contractors. Each one is drawn from the way assessments actually go wrong — not theory.

✓ PROVE IT

The evidence an assessor will ask for. If a section leaves you with nothing to put in a folder, re-read it — every requirement ends in proof.

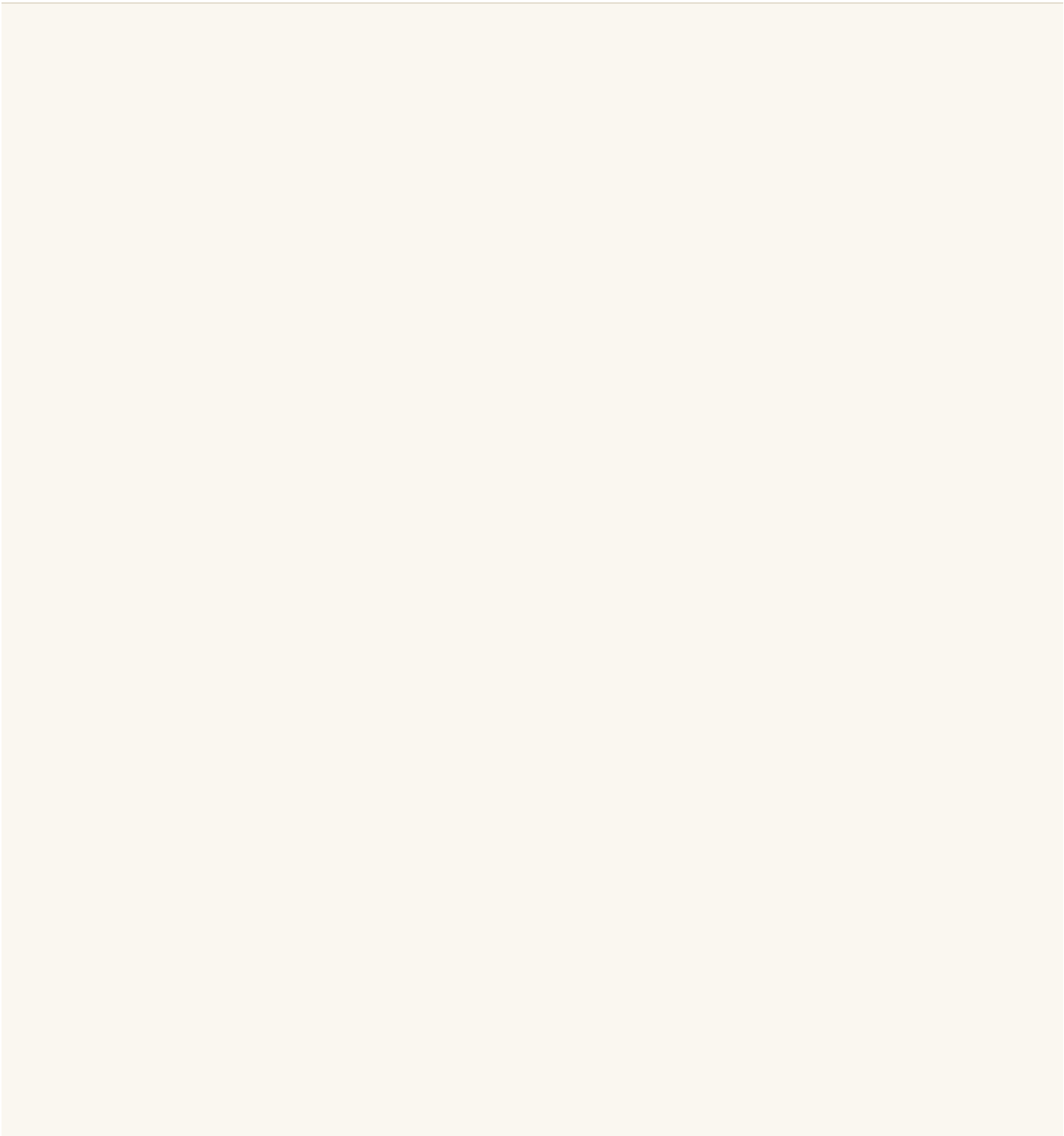
X HONESTY BOX — WHAT THIS GUIDE IS, AND IS NOT

**It is** a plain-language learning and preparation aid, written against the official sources listed on the last page and reviewed for accuracy. **It is not** legal advice, an official DoD or Cyber AB publication, a substitute for the CMMC Assessment Guides, or a promise of any assessment outcome. No document can guarantee a result — only your implementation can. It confers no CMMC status; a CMMC status is granted only through an assessment recorded in SPRS. Where this guide and an official document disagree, the official document wins.

## MEET THE CAST

| NAME          | WHO THEY ARE IN THIS STORY                                                        |
|---------------|-----------------------------------------------------------------------------------|
| You (the OSA) | The "Organization Seeking Assessment." Your company, your systems, your evidence. |

|                 |                                                                                                                                                           |
|-----------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>DoD</b>      | Writes the rules (32 CFR Part 170, DFARS clauses) and owns the CUI you're protecting.                                                                     |
| <b>C3PAO</b>    | CMMC Third-Party Assessment Organization — the accredited company that performs your Level 2 certification assessment. Found on the Cyber AB Marketplace. |
| <b>Cyber AB</b> | The accreditation body that authorizes C3PAOs and credentials assessors.                                                                                  |
| <b>DIBCAC</b>   | The Defense Contract Management Agency's assessment arm. Runs Level 3 assessments and some government-led reviews.                                        |
| <b>SPRS</b>     | Supplier Performance Risk System — the DoD database where your score, status, and affirmations live. Contracting officers check it.                       |



# THE 60-SECOND BRIEFING

**CMMC** (Cybersecurity Maturity Model Certification) is the Department of Defense's way of making one thing checkable: *if we hand you sensitive information, can you actually protect it — and can you prove it?*

Two kinds of information drive everything:

| TERM | PLAIN MEANING                                                                                                                                                                       | EXAMPLE                                                                                    |
|------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------|
| FCI  | Federal Contract Information — non-public info provided by or created for the government under contract. Almost every federal contractor has some.                                  | A statement of work, contract emails, delivery schedules.                                  |
| CUI  | Controlled Unclassified Information — unclassified, but sensitive enough that a law, regulation, or government-wide policy requires protecting it. This is what Level 2 exists for. | Controlled technical drawings, export-controlled specs, some program and sustainment data. |

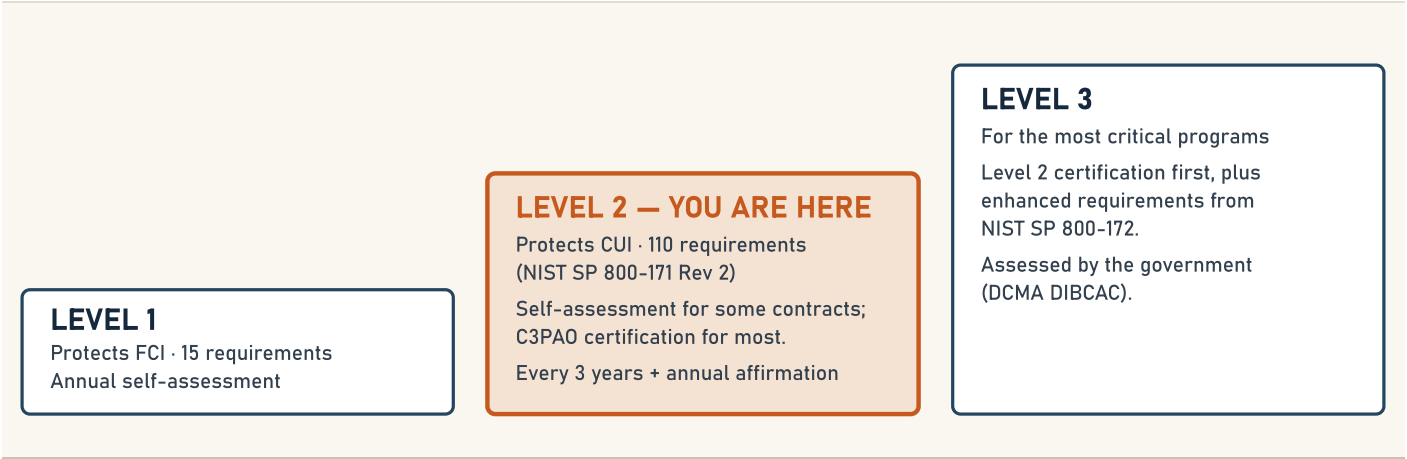


Figure 1 — The three CMMC levels. The contract tells you which level applies; CUI on your systems means Level 2.

## THE FOUR CONTRACT CLAUSES THAT PUT YOU HERE

| DFARS CLAUSE | WHAT IT OBLIGATES YOU TO DO                                                                                                                                                                                        |
|--------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 252.204-7012 | Safeguard covered defense information using NIST SP 800-171; report cyber incidents to DoD within <b>72 hours</b> via DIBNet; cloud services holding that data must meet <b>FedRAMP Moderate</b> (or equivalency). |
| 252.204-7019 | Have a current (within 3 years) SP 800-171 self-assessment score <b>posted in SPRS</b> to be considered for award.                                                                                                 |
| 252.204-7020 | Give the government access to verify that score, and flow the requirement down to subcontractors.                                                                                                                  |
| 252.204-7021 | Hold the specified <b>CMMC level</b> as a condition of award — this is the clause that makes CMMC contractual.                                                                                                     |

#### ■ TRAIL MARKER — WHEN DOES CMMC ACTUALLY HIT YOUR CONTRACTS?

CMMC is phasing in. The program rule (32 CFR Part 170) took effect in December 2024, and under the acquisition rule the CMMC clause began appearing in new DoD solicitations in **late 2025** — starting with self-assessment requirements (Phase 1 — though DoD may require certification in some early solicitations at its discretion), then adding C3PAO certification requirements broadly in later phases over roughly the following three years until full implementation. Two practical consequences: check every new solicitation for the -7021 clause and its specified level, and **don't wait for the clause to appear** — by the time it's in a solicitation you want to bid, it is too late to start a months-long readiness effort.

#### ▲ WATCH OUT — SUBCONTRACTORS ARE NOT EXEMPT

If a prime flows CUI down to you, you need your own Level 2 status — your own scope, your own SSP, your own score in SPRS. "The prime handles compliance" is a sentence that ends bids. Ask your prime, in writing, what data you will receive and what level your subcontract requires.

#### ■ TRAIL MARKER — THE ONE RULE UNDER ALL 110 RULES

Assessors grade each requirement **MET**, **NOT MET**, or **N/A** — and MET means *every one* of that requirement's assessment objectives (there are 320 across the 110 requirements) is satisfied with real, final evidence. Saying "we're secure" earns nothing. Showing a policy, a screenshot of the live setting, and a record of it actually happening — that earns MET. That's the whole game.

## THE WHOLE JOURNEY ON ONE PAGE

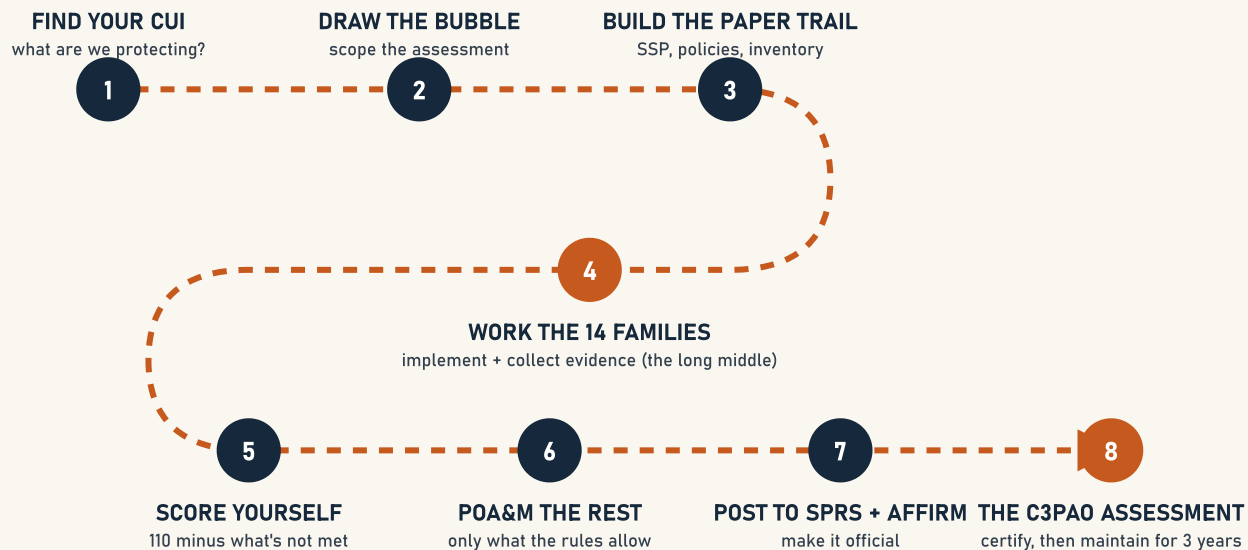


Figure 2 — Eight waypoints. Steps 1–3 are thinking and writing. Step 4 is the long middle. Steps 5–8 are proving.

#### ■ TRAIL MARKER — HOW LONG DOES THIS REALLY TAKE?

For a small business starting from a typical IT setup, closing the gap to Level 2 commonly takes **months to a year or more**, depending on how much CUI you touch and how tightly you scope. The single biggest schedule lever is Waypoint 2: a small, well-fenced CUI environment can cut the work dramatically. Start before the contract that needs it — C3PAO calendars also book out.

#### ▲ WATCH OUT — THE ORDER MATTERS

Teams that start buying security tools before they've drawn the bubble (Waypoint 2) end up securing everything, proving nothing, and paying twice. Scope first. Write second. Implement third. Prove always.

# 1

## FIND YOUR CUI

You cannot protect — or scope — what you haven't located.

CUI is unclassified information the government says must be protected because a law, regulation, or government-wide policy requires it. Your contract, its attachments (look for DD Form 254 on classified-adjacent work, CUI markings, and Section H/I clauses), and the customer's program office tell you what CUI you'll receive or create. The official catalog of categories is the **National Archives (NARA) CUI Registry**.

### WHERE CUI ACTUALLY HIDES IN A SMALL SHOP

- **Email** — the #1 hiding place. Attachments from the prime or program office land here first.
- **File shares and cloud drives** — "Projects\Navy\drawings" folders that grew organically.
- **Engineering tools** — CAD files, source code repositories, test data, build servers.
- **Laptops and home offices** — synced copies, downloads, and USB "temporary" copies.
- **Paper** — printed drawings, travelers on the shop floor, binders from site visits.
- **Backups** — every copy of CUI is CUI, including the ones your backup tool made at 2 a.m.

#### ✓ WHAT GOOD LOOKS LIKE

- A short written statement: "We receive export-controlled technical data from [prime] under contract [#]; it arrives by [method] and lives in [locations]."
- A data-flow sketch: how CUI enters, where it's stored, who touches it, how it leaves.
- Someone owns the question — one named person can answer "where is our CUI?" in one minute.

#### ✗ WHAT GETS YOU HURT

- "We probably don't have CUI." (Said while a folder called ITAR\_drawings sits on the shared drive.)
- Treating *everything* as CUI "to be safe" — you just tripled your scope and your cost.
- Nobody can say which contract requires what — so nobody can say what's in scope.

#### ✓ PROVE IT — WHAT GOES IN THE FOLDER

The contract clause pages, your CUI identification memo, the data-flow sketch, and (if you generate CUI) how you mark it — CUI banner markings, category markings, and a designation indicator on documents you create. Expect to be asked, early in the assessment, "walk me through how CUI enters your company." Have the one-minute answer rehearsed.

#### ▲ WATCH OUT — FCI-ONLY MEANS LEVEL 1, NOT LEVEL 0

If you truly handle no CUI, Level 2 may not apply to you — but FCI still puts you in Level 1's 15 requirements with an annual self-assessment and affirmation. Confirm against the contract before spending on the wrong level.

## 2

## DRAW THE BUBBLE (SCOPING)

The assessment boundary decides what gets assessed — and what you pay.

Before a single control is marked, you must define the **CMMC Assessment Scope**: every asset that processes, stores, or transmits CUI, plus everything that protects those assets. The official Level 2 Scoping Guide sorts every asset you own into five buckets:

| ASSET CATEGORY                        | PLAIN MEANING                                                                                                               | WHAT YOU MUST DO                                                                          |
|---------------------------------------|-----------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------|
| <b>CUI Assets</b>                     | Systems that process, store, or transmit CUI.                                                                               | Inventory, diagram, describe in the SSP, assess against all applicable requirements.      |
| <b>Security Protection Assets</b>     | Things that protect the CUI environment: firewall, identity provider, EDR, SIEM, backup system, the MSP's management tools. | Inventory, diagram, describe in the SSP, assess for the security functions they provide.  |
| <b>Contractor Risk Managed Assets</b> | Could touch CUI but are not intended to, because your policies and controls keep them away.                                 | Inventory, diagram, document the risk-based treatment in the SSP; be ready to justify it. |
| <b>Specialized Assets</b>             | IoT, OT, test equipment, government-furnished equipment — things that can't be secured like a normal computer.              | Inventory, diagram, describe in the SSP; manage by risk-based policy.                     |
| <b>Out-of-Scope Assets</b>            | Physically or logically separated; <i>cannot</i> touch CUI and don't protect CUI assets.                                    | Be ready to show <i>why</i> they truly can't. Separation must be real, not aspirational.  |

### THE BUBBLE — CMMC ASSESSMENT SCOPE

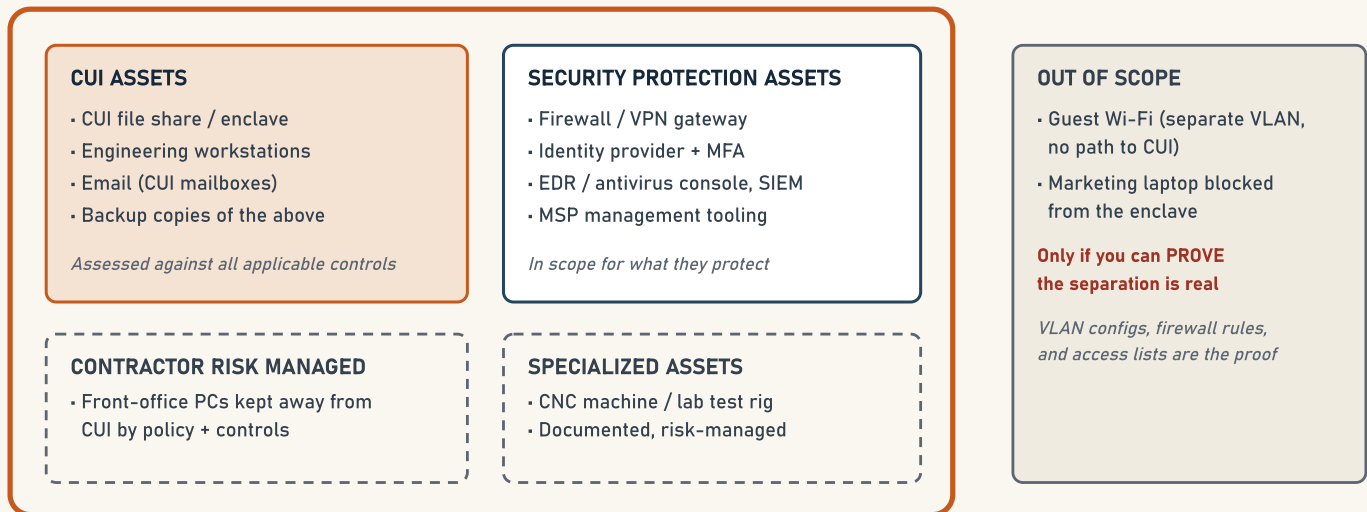


Figure 3 — A typical small-contractor scope. Everything inside the orange line appears in your SSP, inventory, and network diagram.

#### ■ TRAIL MARKER — THE ENCLAVE STRATEGY

The cheapest Level 2 is a **small** Level 2. Instead of certifying your whole flat network, fence CUI into a dedicated enclave — a segmented network zone, a GCC High tenant, or a purpose-built secure workspace — and let the rest of the company stay ordinary. Smaller bubble, fewer assets, fewer interviews, less evidence, lower cost. Segmentation must be enforced (firewall rules, VLANs, access control), not just drawn.



#### ▲ WATCH OUT — CLOUDS AND OUTSIDE HELPERS ARE IN YOUR STORY

If a cloud service **stores, processes, or transmits CUI** (email, file sharing, project tools), DFARS 252.204-7012 requires it to meet **FedRAMP Moderate or equivalency** — commercial consumer tiers usually don't. If an **MSP or other External Service Provider** manages your environment, their access and tooling are part of your assessment: document in the SSP what they do, and get a written **shared responsibility matrix** saying who does which control. "Our IT guy handles that" is not a control.

#### ✓ PROVE IT — THE SCOPING PACK

Asset inventory sorted into the five categories; a network diagram showing the boundary and data flows; the SSP scope section; evidence that separation works (VLAN/firewall configs, screenshots of blocked access). This pack is the first thing a C3PAO reviews — it decides whether the assessment can even be planned.

## 1 · THE SYSTEM SECURITY PLAN (SSP) — THE MASTER DOCUMENT

The SSP is the story of your CUI environment in writing: what the system is, where its boundary sits, how each of the 110 requirements is implemented (or why one doesn't apply), and who is responsible. Assessors read it *first* and test your reality against it.

### X TRAP — NO SSP, NO ASSESSMENT

The SSP (requirement 3.12.4) is special. Under the DoD scoring methodology it carries no point value — because **if the SSP is missing, the assessment cannot be conducted at all**. It can never be put on a POA&M. Some checklists show it as a 1-point item; treat that as a footnote. The real value of the SSP is "everything."

**A workable small-business SSP contains:** system description and boundary (with diagram) · environment of operation · the asset inventory by scoping category · for each requirement, 2–6 sentences on *how* it's met, *where* it's configured, and *who* owns it · connections to other systems and ESPs · N/A justifications · a revision history showing it's maintained, with a defined update frequency.

## 2 · POLICIES AND PROCEDURES — THE RULES YOU PROMISE TO FOLLOW

A **policy** says what must happen ("All remote access requires MFA"). A **procedure** says how it happens here ("New hires get MFA enrolled by IT during onboarding, ticket type X"). **Evidence** shows it happened ("Enrollment report, dated, all 23 users"). You need all three layers, and they must agree with each other.

### ✓ A POLICY AN ASSESSOR BELIEVES

- Approved and signed by leadership, with a date and version number.
- Says who, what, and how often — in numbers ("review access quarterly"), not vibes ("periodically as needed").
- Matches reality. The screen lock policy says 15 minutes; the GPO says 15 minutes.

### X A POLICY THAT FALLS APART

- Watermarked DRAFT, unsigned, or "template" language still saying [Company Name].
- Downloaded the week before the assessment; no one interviewed has read it.
- Promises things you don't do — a policy you violate is worse than none: it proves the control isn't operating.

## 3 · THE POA&M — YOUR HONEST TO-DO LIST

The Plan of Action & Milestones lists every NOT MET requirement with an owner, the fix, milestones, and a completion date. It is a managed promise, not a parking lot — Waypoint 6 covers the strict rules about what may sit on it and for how long.

## THE EVIDENCE BINDER — ONE FOLDER PER FAMILY

Set the structure up *now* so evidence lands in the right place all year:

| FOLDER                   | WHAT LIVES INSIDE                                                                                                   |
|--------------------------|---------------------------------------------------------------------------------------------------------------------|
| 01_Scope_and_SSP\        | SSP, network diagram, asset inventory, data-flow sketch                                                             |
| 02_Policies\             | Signed policies and procedures, version history                                                                     |
| AC\ ... SI\ (14 folders) | Per-family proof: configuration exports, screenshots (named + dated), reports, sample tickets, logs, review records |
| POAM\                    | The living POA&M and closure evidence for each finished item                                                        |
| SPRS\                    | Score worksheet, submission confirmations, affirmation records                                                      |

✓ PROVE IT — THE TWO-PART PROOF RULE

For every requirement, aim for **(1) the rule written down** and **(2) the rule happening** — a live setting, plus one real example (a ticket, a log line, a completed record). One screenshot of a checkbox proves a moment; a dated policy + the setting + a worked example proves a practice.

# 4

## WORK THE 14 FAMILIES

The field guide: every requirement, in plain words, with its point value and POA&M status.

All 110 requirements sort into 14 families. The next pages give each family a card: what it means in plain English, what you must be able to show, a pathway to get there, and a table of every requirement in the family.

### HOW TO READ THE TABLES

| COLUMN | MEANING                                                                                                                                                                                                                                                   |
|--------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID     | The NIST SP 800-171 number. CMMC documents write it long-form — 3.1.1 appears as AC.L2-3.1.1. Same requirement.                                                                                                                                           |
| Points | What you lose from your score of 110 while it's NOT MET: <b>5</b> = critical basics, <b>3</b> = significant, <b>1</b> = still mandatory. <b>3/5</b> = partial-credit special case. <b>SSP</b> = unscored showstopper.                                     |
| POA&M? | Whether the item could sit on a POA&M at assessment time (Waypoint 6): <b>✓ eligible</b> (1-point items), <b>X no</b> — must be MET (3- and 5-point items, with one partial exception), or <b>NEVER</b> (the six that block Conditional status outright). |

#### ■ TRAIL MARKER — EVERY POINT VALUE IN ONE GLANCE

Of the 110: **44 requirements are worth 5 points** (including the two partial-credit cases at full weight), **14 are worth 3, 51 are worth 1**, and the **SSP is unscored** — it simply must exist. Lose everything and the score bottoms out at -203. The 5-pointers are DoD's list of "this failing is how breaches happen" — work them first.

#### ▲ WATCH OUT — "MET" IS OBJECTIVE-BY-OBJECTIVE

Each requirement breaks into assessment objectives (320 in total, listed in NIST SP 800-171A and the CMMC Assessment Guide). A requirement is MET only when *every applicable objective* is satisfied. 3.1.1 alone has six objectives — identifying users, processes, and devices, *and* limiting access to each. Check the objectives, not the title.

#### ■ TRAIL MARKER — THE HONEST ORDER OF WORK

1) Anything on the **never-POA&M list** (3.1.20, 3.1.22, 3.10.3, 3.10.4, 3.10.5 — and the SSP itself). 2) The **5-pointers**. 3) The **3-pointers**. 4) The 1-pointers. This order clears eligibility blockers first and buys the most score per hour of work.

"Who may enter, which rooms, with which keys."

Decide who is allowed into your systems, what each person can do once inside, and how outside connections (remote, wireless, mobile, portable media, public posting) are controlled. AC is the biggest family and carries seven 5-pointers — it is where most score lives.

### ✓ WHAT YOU MUST BE ABLE TO SHOW

- ✓ A current user list with roles, and an approval record for each account.
- ✓ Live settings: permissions by role, remote access via VPN/gateway with encryption, Wi-Fi with WPA2/WPA3-Enterprise or equivalent, session lock.
- ✓ Rules for USB drives, mobile devices, and a review step before anything is posted publicly.

### → YOUR PATHWAY

- 1 Export the full account list; delete or disable what you can't justify.
- 2 Map roles → permissions; remove "everyone is admin."
- 3 Force all remote access through one managed, encrypted gate.
- 4 Lock down Wi-Fi, mobile devices, and USB by written rule + technical control.
- 5 Name who may approve public posts, and add a CUI check to that step.
- 6 Centralize session-lock and lockout settings (GPO/MDM) so they can't drift machine by machine.
- 7 Run a quarterly access review — one hour, re-approve every account and permission, keep the minutes.

| ID     | NAME                           | IN PLAIN WORDS                                                 | POINTS | POA&M?        |
|--------|--------------------------------|----------------------------------------------------------------|--------|---------------|
| 3.1.1  | Authorized access control      | Only approved people, programs, and devices get in.            | 5      | X must be MET |
| 3.1.2  | Transaction & function control | People can only use the functions their job needs.             | 5      | X must be MET |
| 3.1.3  | Control CUI flow               | CUI travels only on approved paths.                            | 1      | ✓ eligible    |
| 3.1.4  | Separation of duties           | Split powerful jobs so no one person holds every key step.     | 1      | ✓ eligible    |
| 3.1.5  | Least privilege                | Give the smallest key ring that still does the job.            | 3      | X must be MET |
| 3.1.6  | Non-privileged account use     | Admins use normal accounts for normal work.                    | 1      | ✓ eligible    |
| 3.1.7  | Privileged functions           | Non-admins can't run admin commands; admin actions are logged. | 1      | ✓ eligible    |
| 3.1.8  | Unsuccessful logon attempts    | Too many wrong passwords locks or slows the account.           | 1      | ✓ eligible    |
| 3.1.9  | Privacy & security notices     | Show the required warning banner at login.                     | 1      | ✓ eligible    |
| 3.1.10 | Session lock                   | Idle screens lock and hide what was showing.                   | 1      | ✓ eligible    |
| 3.1.11 | Session termination            | Sessions end automatically on defined conditions.              | 1      | ✓ eligible    |
| 3.1.12 | Control remote access          | Remote sessions are permitted, controlled, and monitored.      | 5      | X must be MET |
| 3.1.13 | Remote access confidentiality  | Remote sessions are encrypted.                                 | 5      | X must be MET |
| 3.1.14 | Remote access routing          | Remote traffic enters only through managed access points.      | 1      | ✓ eligible    |
| 3.1.15 | Privileged remote access       | Remote admin work needs specific authorization.                | 1      | ✓ eligible    |

| ID     | NAME                                 | IN PLAIN WORDS                                                  | POINTS | POA&M?         |
|--------|--------------------------------------|-----------------------------------------------------------------|--------|----------------|
| 3.1.16 | Wireless access authorization        | Wi-Fi access points are approved before use.                    | 5      | X must be MET  |
| 3.1.17 | Wireless access protection           | Wi-Fi requires authentication and encryption.                   | 5      | X must be MET  |
| 3.1.18 | Mobile device connection             | Phones/tablets that connect are identified, authorized, logged. | 5      | X must be MET  |
| 3.1.19 | Encrypt CUI on mobile                | CUI on mobile devices/platforms is encrypted.                   | 3      | X must be MET  |
| 3.1.20 | External connections                 | Outside systems you use are identified, verified, and limited.  | 1      | NEVER ON POA&M |
| 3.1.21 | Portable storage on external systems | Company CUI on thumb drives used outside is limited by rule.    | 1      | ✓ eligible     |
| 3.1.22 | Control public information           | A review step keeps CUI off websites and social posts.          | 1      | NEVER ON POA&M |

## AT

## AWARENESS &amp; TRAINING — 3 REQUIREMENTS

"Practice before the game."

People can't follow rules they've never heard. Everyone gets security awareness training; people with security duties get role-based training; everyone learns to spot insider threat indicators.

#### ✓ WHAT YOU MUST BE ABLE TO SHOW

- ✓ Training content (slides, LMS course) covering CUI handling and your actual policies.
- ✓ Completion records with names and dates — including new hires and annual refreshers.
- ✓ Role-based material for admins and security staff; insider-threat content for all.

#### → YOUR PATHWAY

- 1 Pick a delivery method (LMS, recorded session, documented in-person).
- 2 Add company-specific content: your CUI, your rules, your reporting path.
- 3 Set the cadence in policy (e.g., at hire + annually) and track completions.
- 4 Between annual cycles, run a short refresher or a phishing exercise and record who took part.
- 5 Write security duties into job descriptions so role-based training (3.2.2) has a clear "who."

| ID    | NAME                      | IN PLAIN WORDS                                                | POINTS | POA&M?        |
|-------|---------------------------|---------------------------------------------------------------|--------|---------------|
| 3.2.1 | Role-based risk awareness | Everyone knows the security risks of their own job.           | 5      | X must be MET |
| 3.2.2 | Role-based training       | People are trained for their assigned security duties.        | 5      | X must be MET |
| 3.2.3 | Insider threat awareness  | People can recognize and report insider-threat warning signs. | 1      | ✓ eligible    |

## AU

## AUDIT &amp; ACCOUNTABILITY — 9 REQUIREMENTS

"The security camera notebook."

Keep logs good enough to answer *who did what, where, and when* — and actually look at them. Logs must trace actions to individuals, survive tampering, share one clock, and alert someone if logging breaks.

#### ✓ WHAT YOU MUST BE ABLE TO SHOW

- ✓ A written list of what events you log and how long you keep them.
- ✓ Live log collection (SIEM or centralized logs) with correlation across sources.
- ✓ Records of periodic log review, an alert for logging failures, NTP time sync, and restricted access to logs.

#### → YOUR PATHWAY

- 1 Define the events that matter (logons, admin actions, failures) and retention.
- 2 Centralize: Windows events, firewall, EDR, cloud audit logs into one place.
- 3 Schedule a recurring log review and *keep a record* each time.
- 4 Alert on "logging stopped"; sync all clocks to one authoritative source.
- 5 No SIEM budget? Start with built-ins — Windows Event Forwarding, syslog to one server, or your cloud tenant's audit log. Centralizing matters more than the brand.
- 6 Limit log-clearing rights to named admins and keep the permission export as evidence.

| ID    | NAME                      | IN PLAIN WORDS                                                      | POINTS | POA&M?        |
|-------|---------------------------|---------------------------------------------------------------------|--------|---------------|
| 3.3.1 | System auditing           | Create and keep the logs needed to replay the story.                | 5      | X must be MET |
| 3.3.2 | User accountability       | Logs tie every action to a specific person or process.              | 3      | X must be MET |
| 3.3.3 | Event review              | Review and update <i>what</i> you log as needs change.              | 1      | ✓ eligible    |
| 3.3.4 | Audit failure alerting    | If logging breaks, the right people get alerted.                    | 1      | ✓ eligible    |
| 3.3.5 | Audit correlation         | Bring logs together so clues can be connected.                      | 5      | X must be MET |
| 3.3.6 | Reduction & reporting     | Turn raw logs into on-demand, readable reports.                     | 1      | ✓ eligible    |
| 3.3.7 | Authoritative time source | All systems share one trusted clock so logs line up.                | 1      | ✓ eligible    |
| 3.3.8 | Audit protection          | Logs and log tools can't be altered or deleted by the wrong people. | 1      | ✓ eligible    |
| 3.3.9 | Audit management          | Only a small set of privileged users manage logging.                | 1      | ✓ eligible    |



"The Lego instruction book."

Know the approved, safe setup of every system — and control every change to it. Six of nine requirements here are 5-pointers, which makes CM the densest concentration of score in the model. The star is 3.4.8: allowlisting or blocklisting what software may run.

#### ✓ WHAT YOU MUST BE ABLE TO SHOW

- ✓ A written baseline (hardening standard) per system type, plus a hardware/software inventory.
- ✓ Change tickets showing track → review → approve → log.
- ✓ Evidence that unnecessary services, ports, and programs are disabled.
- ✓ Your allow/deny software policy and the live mechanism enforcing it (e.g., an application-control tool or managed software policy).

#### → YOUR PATHWAY

- 1 Write a one-page baseline per system type (start from CIS or DISA STIG guidance, trimmed to fit).
- 2 Stand up a lightweight change log — even a ticket queue works.
- 3 Turn off what you don't use; document what you keep.
- 4 Decide allowlist vs blocklist, write it down, enforce it with tooling.
- 5 Prove enforcement, not intent: a monthly settings export or config scan compared against the baseline.
- 6 Tie the inventory to purchasing and disposal so it updates when hardware changes — not once a year.

| ID    | NAME                               | IN PLAIN WORDS                                                                 | POINTS | POA&M?        |
|-------|------------------------------------|--------------------------------------------------------------------------------|--------|---------------|
| 3.4.1 | System baselining                  | Write down the approved setup + keep a system inventory.                       | 5      | X must be MET |
| 3.4.2 | Security configuration enforcement | Systems actually follow the safe setup — no drift.                             | 5      | X must be MET |
| 3.4.3 | System change management           | Changes are tracked, reviewed, approved, and logged.                           | 1      | ✓ eligible    |
| 3.4.4 | Security impact analysis           | Think through security impact before you change things.                        | 1      | ✓ eligible    |
| 3.4.5 | Access restrictions for change     | Only authorized people can change systems.                                     | 5      | X must be MET |
| 3.4.6 | Least functionality                | Systems provide only what's essential.                                         | 5      | X must be MET |
| 3.4.7 | Nonessential functionality         | Unneeded programs, ports, protocols, services are off.                         | 5      | X must be MET |
| 3.4.8 | Application execution policy       | Only approved software runs (allowlist), or banned software can't (blocklist). | 5      | X must be MET |
| 3.4.9 | User-installed software            | User software installs are controlled and monitored.                           | 1      | ✓ eligible    |

## IA

## IDENTIFICATION &amp; AUTHENTICATION — 11 REQUIREMENTS

"Name tag plus secret handshake."

Every user, process, and device proves who it is before getting in. The heart of the family is 3.5.3 — multifactor authentication — one of only two requirements in the whole model with partial credit.

### ✓ WHAT YOU MUST BE ABLE TO SHOW

- ✓ Unique accounts for everyone (no shared logins), incl. service accounts.
- ✓ MFA live for: local *and* network access to privileged accounts, and network access for everyone else.
- ✓ Password policy settings (complexity, reuse, temporary passwords) and hashed/encrypted password storage and transmission.

### → YOUR PATHWAY

- 1 Kill shared accounts; give every human and service its own identity.
- 2 Roll out MFA — privileged accounts first, then all network access.
- 3 Set password rules in the identity system, not just on paper.
- 4 Disable accounts after a defined idle period; automate it.
- 5 Prefer stronger factors over SMS codes — an authenticator app at minimum, a phishing-resistant FIDO2 key where you can.
- 6 Inventory service accounts separately — each gets a named owner and a documented purpose.

| ID     | NAME                                  | IN PLAIN WORDS                                                        | POINTS | POA&M?           |
|--------|---------------------------------------|-----------------------------------------------------------------------|--------|------------------|
| 3.5.1  | Identification                        | Every user, process, and device has a unique ID.                      | 5      | X must be MET    |
| 3.5.2  | Authentication                        | Identity is verified before access is granted.                        | 5      | X must be MET    |
| 3.5.3  | Multifactor authentication            | MFA for privileged accounts (local + network) and all network access. | 3/5    | X see Waypoint 6 |
| 3.5.4  | Replay-resistant authentication       | Logins can't be captured and replayed by an attacker.                 | 1      | ✓ eligible       |
| 3.5.5  | Identifier reuse                      | Old usernames aren't recycled for a defined period.                   | 1      | ✓ eligible       |
| 3.5.6  | Identifier handling                   | Inactive accounts get disabled after a defined period.                | 1      | ✓ eligible       |
| 3.5.7  | Password complexity                   | New passwords meet your written strength rules.                       | 1      | ✓ eligible       |
| 3.5.8  | Password reuse                        | Old passwords can't be recycled for N generations.                    | 1      | ✓ eligible       |
| 3.5.9  | Temporary passwords                   | Temp passwords must be changed immediately at first logon.            | 1      | ✓ eligible       |
| 3.5.10 | Cryptographically-protected passwords | Passwords are protected (hashed/encrypted) in storage and transit.    | 5      | X must be MET    |
| 3.5.11 | Obscure feedback                      | Passwords are hidden as people type them.                             | 1      | ✓ eligible       |

## IR

## INCIDENT RESPONSE — 3 REQUIREMENTS

"The fire drill plan."

Have a real plan for cyber trouble: detect it, contain it, recover from it, report it, and practice the whole thing before it's real. Remember the contract side too: DFARS 252.204-7012 gives you **72 hours** to report a cyber incident to DoD via `dibnet.dod.mil` (you'll need a DoD-approved medium-assurance certificate to file — get it *before* you need it).

### ✓ WHAT YOU MUST BE ABLE TO SHOW

- ✓ A written incident response plan with phases: prepare, detect, analyze, contain, recover, respond.
- ✓ An incident log — even "suspicious email, investigated, benign" counts as operational evidence.
- ✓ A tabletop exercise record with date, participants, and lessons learned.

### → YOUR PATHWAY

- 1 Write the plan; name roles by title, with a wallet-card contact list.
- 2 Register for DIBNet reporting now (certificate takes time).
- 3 Run one tabletop per year minimum; document it.
- 4 Put the "who to call" card in onboarding and the break room — reporting speed depends on it.
- 5 After any event, even a false alarm, file a five-line lessons-learned note. It's cheap, and it's evidence.

| ID    | NAME                          | IN PLAIN WORDS                                                                               | POINTS | POA&M?        |
|-------|-------------------------------|----------------------------------------------------------------------------------------------|--------|---------------|
| 3.6.1 | Incident handling             | A working capability: prepare, detect, analyze, contain, recover, respond.                   | 5      | X must be MET |
| 3.6.2 | Incident tracking & reporting | Incidents are tracked, documented, and reported to the designated officials and authorities. | 5      | X must be MET |
| 3.6.3 | Incident response testing     | Practice the plan — like a fire drill — and keep the record.                                 | 1      | ✓ eligible    |

## MA

## MAINTENANCE — 6 REQUIREMENTS

"The fix-it log."

When systems get repaired — by you or a vendor — control who does it, what tools they bring, and what leaves the building. Remote (nonlocal) maintenance needs MFA and must be disconnected when done.

#### ✓ WHAT YOU MUST BE ABLE TO SHOW

- ✓ Maintenance records: who, what, when, on which asset.
- ✓ Sanitization records for anything sent off-site for repair.
- ✓ Malware checks on vendor diagnostic media; supervision records for unescorted-ineligible technicians.

#### → YOUR PATHWAY

- 1 Add a maintenance ticket type to whatever queue you already run.
- 2 Rule: nothing leaves for repair with CUI on it — wipe or pull the drive, record it.
- 3 Vendor remote sessions: MFA in, monitored, disconnected after.
- 4 Keep a one-line-per-visit log: date, technician, what was touched, escort initials.
- 5 Scan vendor diagnostic tools on an isolated or non-production machine before they touch in-scope systems.

| ID    | NAME                   | IN PLAIN WORDS                                                  | POINTS | POA&M?        |
|-------|------------------------|-----------------------------------------------------------------|--------|---------------|
| 3.7.1 | Perform maintenance    | Systems are maintained — patched, serviced, repaired.           | 3      | X must be MET |
| 3.7.2 | Maintenance control    | Tools, techniques, and people doing maintenance are controlled. | 5      | X must be MET |
| 3.7.3 | Equipment sanitization | Gear leaving for off-site repair is scrubbed of CUI first.      | 1      | ✓ eligible    |
| 3.7.4 | Media inspection       | Vendor diagnostic disks/USBs are malware-checked before use.    | 3      | X must be MET |
| 3.7.5 | Nonlocal maintenance   | Remote maintenance uses MFA and is disconnected when complete.  | 5      | X must be MET |
| 3.7.6 | Maintenance personnel  | Technicians without authorization are supervised.               | 1      | ✓ eligible    |

## MP

## MEDIA PROTECTION — 9 REQUIREMENTS

"The locked backpack."

Protect CUI wherever it sits outside a running system: paper, USB drives, external disks, backup media. Control it, mark it, encrypt it in transport, and destroy it properly at end of life.

### ✓ WHAT YOU MUST BE ABLE TO SHOW

- ✓ Locked storage for CUI media and paper; an access rule for who may retrieve it.
- ✓ Destruction/sanitization certificates (or your own signed wipe records).
- ✓ USB control settings; encryption for media leaving the building; protected backups.

### → YOUR PATHWAY

- 1 Buy a lockable cabinet; make it the only home for CUI media and paper.
- 2 Technically restrict USB use; ban unowned/found devices outright.
- 3 Encrypt anything CUI that travels; verify backup encryption settings.
- 4 Adopt NIST SP 800-88 media sanitization practices for disposal and keep the records.
- 5 Keep a simple media inventory with a checkout sheet — what exists, where it lives, who has it.
- 6 Set backups to encrypt by default and re-verify the setting after backup-software updates.

| ID    | NAME                        | IN PLAIN WORDS                                                             | POINTS | POA&M?        |
|-------|-----------------------------|----------------------------------------------------------------------------|--------|---------------|
| 3.8.1 | Media protection            | CUI on paper and digital media is physically controlled and stored safely. | 3      | X must be MET |
| 3.8.2 | Media access                | Only authorized people can access CUI media.                               | 3      | X must be MET |
| 3.8.3 | Media disposal              | Media is sanitized or destroyed before disposal or reuse.                  | 5      | X must be MET |
| 3.8.4 | Media markings              | CUI media carries the required markings and limits.                        | 1      | ✓ eligible    |
| 3.8.5 | Media accountability        | Media leaving controlled areas is tracked and controlled in transport.     | 1      | ✓ eligible    |
| 3.8.6 | Portable storage encryption | CUI on media in transport is encrypted (or physically safeguarded).        | 1      | ✓ eligible    |
| 3.8.7 | Removable media             | Use of removable media (USB drives) is controlled by rule + setting.       | 5      | X must be MET |
| 3.8.8 | Shared / ownerless media    | Portable storage with no identifiable owner is banned.                     | 3      | X must be MET |
| 3.8.9 | Protect backups             | Backup copies of CUI are protected where they're stored.                   | 1      | ✓ eligible    |

## PS

## PERSONNEL SECURITY — 2 REQUIREMENTS

"People safety checks."

Two requirements, giant consequences: screen people before they touch CUI, and cut access *fast* when they leave or change roles. 3.9.2 is a 5-pointer because orphaned accounts of ex-employees are a classic breach path.

### ✓ WHAT YOU MUST BE ABLE TO SHOW

- ✓ Your written screening standard (e.g., background check level) and a record it ran for CUI-access staff.
- ✓ A termination/transfer checklist with same-day access removal — plus a completed example with the ticket trail.

### → YOUR PATHWAY

- 1 Write the screening rule that matches your risk and state law; apply it consistently.
- 2 Build the offboarding checklist with HR; make IT sign-off a required line.
- 3 Test it: pick a recent departure and pull the evidence end-to-end.
- 4 Handle transfers, not just exits: on a role change, re-run the person's access against the new role.
- 5 Pre-stage a same-day disable checklist with IT so offboarding never waits for whoever's on vacation.

| ID    | NAME               | IN PLAIN WORDS                                         | POINTS | POA&M?        |
|-------|--------------------|--------------------------------------------------------|--------|---------------|
| 3.9.1 | Screen individuals | People are screened before getting CUI access.         | 3      | X must be MET |
| 3.9.2 | Personnel actions  | Access is removed promptly on termination or transfer. | 5      | X must be MET |

## PE

## PHYSICAL PROTECTION — 6 REQUIREMENTS

"Locked doors and visitor badges."

Protect the rooms where CUI and CUI systems live. Note carefully: **three of these six requirements (3.10.3, 3.10.4, 3.10.5) can never be placed on a POA&M** — visitor escorts, physical access logs, and badge/key management must simply be working on assessment day. They're cheap to fix and fatal to skip.

### ✓ WHAT YOU MUST BE ABLE TO SHOW

- ✓ The list of who has physical access (badges/keys) and a periodic review of it.
- ✓ A visitor log with escort initials — with real entries, not a fresh empty book.
- ✓ Facility monitoring (cameras/alarm) evidence; a home/remote work rule for CUI.

### → YOUR PATHWAY

- 1 Put a sign-in sheet and escort rule at the door *today*; brief the front desk.
- 2 Inventory badges and keys; recover strays; log issuance.
- 3 Define alternate-work-site rules (locked screens, no CUI printing at home, VPN required).
- 4 Review the visitor log and badge list monthly; initial and date the review on the log itself.
- 5 Photograph the physical controls — locked rack, cabinet, cameras — for the evidence binder.

| ID     | NAME                  | IN PLAIN WORDS                                           | POINTS | POA&M?        |
|--------|-----------------------|----------------------------------------------------------|--------|---------------|
| 3.10.1 | Limit physical access | Only authorized people can physically reach CUI systems. | 5      | X must be MET |

| ID     | NAME                   | IN PLAIN WORDS                                                  | POINTS | POA&M?         |
|--------|------------------------|-----------------------------------------------------------------|--------|----------------|
| 3.10.2 | Monitor facility       | The facility and its support systems are protected and watched. | 5      | X must be MET  |
| 3.10.3 | Escort visitors        | Visitors are escorted and their activity monitored.             | 1      | NEVER ON POA&M |
| 3.10.4 | Physical access logs   | Keep records of who entered CUI areas.                          | 1      | NEVER ON POA&M |
| 3.10.5 | Manage physical access | Badges, keys, and fobs are inventoried and controlled.          | 1      | NEVER ON POA&M |
| 3.10.6 | Alternative work sites | Home and remote sites follow defined CUI safeguards.            | 1      | ✓ eligible     |

## RA

## RISK ASSESSMENT — 3 REQUIREMENTS

"Look for weak spots."

On a schedule you define: assess risk, scan for vulnerabilities, and fix what you find in risk order. The evidence is the cadence — one old scan proves almost nothing; a rhythm of scans with remediation tickets proves a practice.

## ✓ WHAT YOU MUST BE ABLE TO SHOW

- ✓ A dated risk assessment (a structured spreadsheet is fine at small scale) and its defined frequency.
- ✓ Vulnerability scan reports on a defined schedule, plus rescans after big new vulnerabilities hit the news.
- ✓ Remediation tickets linking findings → fixes, prioritized by risk.

## → YOUR PATHWAY

- 1 Pick a scanner; scan everything in scope; calendar the recurrence.
- 2 Triage: critical/high first, with dates and owners in tickets.
- 3 Once or twice a year, sit down and write the risk assessment. Date it.
- 4 Watch CISA's Known Exploited Vulnerabilities (KEV) catalog; a KEV hit on your stack is a scan-now trigger.
- 5 Keep the risk register short and living — five real risks reviewed twice a year beat fifty stale ones.

| ID     | NAME                      | IN PLAIN WORDS                                                 | POINTS | POA&M?        |
|--------|---------------------------|----------------------------------------------------------------|--------|---------------|
| 3.11.1 | Risk assessments          | Periodically ask "what could hurt our CUI, and how badly?"     | 3      | X must be MET |
| 3.11.2 | Vulnerability scanning    | Scan systems and apps on schedule and when new threats emerge. | 5      | X must be MET |
| 3.11.3 | Vulnerability remediation | Fix findings in risk order.                                    | 1      | ✓ eligible    |

## CA

## SECURITY ASSESSMENT — 4 REQUIREMENTS

"The report card you give yourself."

Check your own controls on a schedule, keep a plan of action for weaknesses, monitor continuously, and maintain the SSP. This family is where the assessment machinery itself lives — including the unscored, never-deferrable SSP requirement, 3.12.4.

## ✓ WHAT YOU MUST BE ABLE TO SHOW

- ✓ A defined self-assessment cadence and the completed results.
- ✓ A living POA&M with owners and dates — reviewed on a schedule, not just before assessments.
- ✓ The SSP itself, current, with revision history.

## → YOUR PATHWAY

- 1 Calendar a control self-check (e.g., annually, plus spot checks quarterly).
- 2 Treat the POA&M as a standing agenda item in ops meetings.
- 3 Update the SSP whenever systems, clouds, or responsibilities change.
- 4 Self-check against the 320 objectives in NIST SP 800-171A — grade yourself the way the assessor will.
- 5 Rotate spot-checks: each quarter, pick two or three controls and pull their evidence end-to-end.

| ID     | NAME                        | IN PLAIN WORDS                                           | POINTS | POA&M?        |
|--------|-----------------------------|----------------------------------------------------------|--------|---------------|
| 3.12.1 | Security control assessment | Periodically test whether your controls actually work.   | 5      | X must be MET |
| 3.12.2 | Operational plan of action  | Track deficiencies in a plan with owners and milestones. | 3      | X must be MET |



| ID     | NAME                        | IN PLAIN WORDS                                                             | POINTS | POA&M?         |
|--------|-----------------------------|----------------------------------------------------------------------------|--------|----------------|
| 3.12.3 | Security control monitoring | Keep watching controls between assessments.                                | 5      | X must be MET  |
| 3.12.4 | System Security Plan        | The master document. Unscored — because without it there is no assessment. | SSP    | NEVER ON POA&M |

"Safe roads for data."

Protect the network paths CUI travels and the places it rests: boundaries, segmentation, deny-by-default firewalls, and encryption. Home of the model's other partial-credit case: 3.13.11, FIPS-validated cryptography.

### ✓ WHAT YOU MUST BE ABLE TO SHOW

- ✓ Firewall rules showing deny-by-default with documented exceptions; the network diagram matching reality.
- ✓ Public-facing systems separated (DMZ/subnet) from the CUI environment.
- ✓ Encryption for CUI in transit and protection at rest — with **CMVP certificate numbers** for the crypto modules where FIPS validation is claimed.

### → YOUR PATHWAY

- 1 Flip the firewall philosophy: block everything, allow by exception, document each exception.
- 2 Segment public/guest systems away from CUI networks.
- 3 Turn on TLS/VPN encryption for every CUI path; disable split tunneling.
- 4 For FIPS: look up each product's module on NIST's CMVP list and file the certificate number in your evidence. "It uses AES" is not validation.
- 5 Export firewall rule sets on a schedule and compare — an unexplained new rule is a finding in waiting.
- 6 Where a platform offers a FIPS mode, consider enabling it — and still record the CMVP certificate for the module version actually in use.

| ID      | NAME                         | IN PLAIN WORDS                                                            | POINTS | POA&M?             |
|---------|------------------------------|---------------------------------------------------------------------------|--------|--------------------|
| 3.13.1  | Boundary protection          | Watch and control traffic at the network's edges and key interior lines.  | 5      | X must be MET      |
| 3.13.2  | Security engineering         | Build security in — architecture and design, not bolt-ons.                | 5      | X must be MET      |
| 3.13.3  | Role separation              | Separate user functions from system-admin functions.                      | 1      | ✓ eligible         |
| 3.13.4  | Shared resource control      | One user's data can't leak to another via shared resources.               | 1      | ✓ eligible         |
| 3.13.5  | Public-access separation     | Public-facing systems live in their own subnetwork (DMZ).                 | 5      | X must be MET      |
| 3.13.6  | Deny by default              | Network traffic is blocked unless explicitly allowed.                     | 5      | X must be MET      |
| 3.13.7  | Split tunneling              | Remote devices can't bridge your network and the internet at once.        | 1      | ✓ eligible         |
| 3.13.8  | Data in transit              | CUI is encrypted while it moves (or physically safeguarded).              | 3      | X must be MET      |
| 3.13.9  | Connection termination       | Network sessions end when done or after defined idle time.                | 1      | ✓ eligible         |
| 3.13.10 | Key management               | Encryption keys are generated, stored, and managed properly.              | 1      | ✓ eligible         |
| 3.13.11 | CUI encryption (FIPS)        | Crypto protecting CUI confidentiality is FIPS-validated.                  | 3/5    | ✓ only the –3 case |
| 3.13.12 | Collaborative device control | Remote switch-on of cameras/mics is prohibited; devices show when in use. | 1      | ✓ eligible         |

| ID      | NAME                        | IN PLAIN WORDS                                                                        | POINTS | POA&M?        |
|---------|-----------------------------|---------------------------------------------------------------------------------------|--------|---------------|
| 3.13.13 | Mobile code                 | Scripts and active content (applets, macros-style code) are controlled and monitored. | 1      | ✓ eligible    |
| 3.13.14 | VoIP                        | Internet phone/voice systems are controlled and monitored.                            | 1      | ✓ eligible    |
| 3.13.15 | Communications authenticity | Sessions are protected against spoofing and hijacking.                                | 5      | X must be MET |
| 3.13.16 | Data at rest                | CUI is protected while stored.                                                        | 1      | ✓ eligible    |

## SYSTEM &amp; INFORMATION INTEGRITY — 7 REQUIREMENTS

"Keep the system healthy."

Patch flaws on a timeline you defined, run malware protection everywhere and keep it updated, watch security alerts and traffic, and notice unauthorized use. Five of seven are 5-pointers — this family is basic hygiene with maximum scoring weight.

### ✓ WHAT YOU MUST BE ABLE TO SHOW

- ✓ A patch policy with defined timeframes (identify → report → correct) and patch reports proving you hit them.
- ✓ EDR/antivirus deployed to every in-scope system, auto-updating, with real-time + scheduled scans.
- ✓ A subscription to security advisories (e.g., CISA alerts, vendor bulletins) and records of acting on them.

### → YOUR PATHWAY

- 1 Write the patch clock (e.g., critical: 14 days) — then measure yourself against it.
- 2 Verify EDR coverage = inventory coverage. Gaps are findings.
- 3 Route advisories to a named person; log the "we checked, we acted" trail.
- 4 Turn on automatic protection updates, then spot-check a device monthly to confirm they're landing.
- 5 Don't forget outbound: an EDR or firewall alert on unusual outbound traffic covers the half of 3.14.6 teams miss.

| ID     | NAME                         | IN PLAIN WORDS                                               | POINTS | POA&M?        |
|--------|------------------------------|--------------------------------------------------------------|--------|---------------|
| 3.14.1 | Flaw remediation             | Find, report, and fix flaws within defined timeframes.       | 5      | X must be MET |
| 3.14.2 | Malicious code protection    | Malware protection runs at designated points.                | 5      | X must be MET |
| 3.14.3 | Security alerts & advisories | Monitor security alerts and act on them.                     | 5      | X must be MET |
| 3.14.4 | Update malware protection    | Protection mechanisms update when new releases ship.         | 5      | X must be MET |
| 3.14.5 | System & file scanning       | Periodic system scans + real-time scans of downloaded files. | 3      | X must be MET |
| 3.14.6 | Monitor communications       | Watch inbound and outbound traffic for attack indicators.    | 5      | X must be MET |
| 3.14.7 | Identify unauthorized use    | Define authorized use; detect what falls outside it.         | 3      | X must be MET |

## 5

## SCORE YOURSELF — AND READ THE SCORE HONESTLY

The math is simple. The eligibility rules are not. Learn both.

## THE MATH

Start at **110**. For every requirement that is NOT MET, subtract its point value (5, 3, or 1). N/A requirements (justified by scope) don't subtract. The floor is **-203**. Two special cases give partial credit:

| REQUIREMENT  | PARTIAL-CREDIT RULE                                                                                                                             |
|--------------|-------------------------------------------------------------------------------------------------------------------------------------------------|
| 3.5.3 MFA    | Subtract <b>3</b> if MFA covers remote access and privileged users but not general users yet; subtract <b>5</b> if it's not implemented at all. |
| 3.13.11 FIPS | Subtract <b>3</b> if encryption protects CUI but isn't FIPS-validated; subtract <b>5</b> if CUI isn't encrypted at all.                         |

## WORKED EXAMPLE — "SCORE 89, STILL NOT ELIGIBLE"

## START: 110 POINTS

3.4.8 software control NOT MET -5

3.13.6 deny-by-default NOT MET -5

3.14.6 traffic monitoring NOT MET -5

3.1.20 external connections -1

five other 1-point items -5

RESULT: 110 - 21 = 89

## THE ELIGIBILITY CHECK

Score ≥ 88? 89 ✓ yes

Everything open ≤ 1 point? X no — three 5-point items are still open

Never-list all clear? X no — 3.1.20 can never sit on a POA&amp;M

**VERDICT: NOT ELIGIBLE for Conditional status at 89 points**

Figure 4 — A contractor at 89 points, above the 88 floor, who still cannot achieve Conditional status. The three open 5-pointers and 3.1.20 must be fixed and MET first — the POA&M cannot absorb them.

## X TRAP — 88 IS NECESSARY, NOT SUFFICIENT

The most expensive misunderstanding in CMMC: treating 88 as a finish line. **88 is only the entry ticket.** Conditional status also requires that *every single open item* is POA&M-eligible. One open 5-pointer — or one item from the never-list — makes you ineligible at *any* score. Aim for MET on everything above 1 point; use the POA&M only for eligible stragglers.

## ✓ PROVE IT — KEEP THE WORKSHEET

Keep the scoring worksheet that shows each requirement's status and deduction, dated, with the assessor-facing evidence reference beside each MET. Your SPRS number should be reproducible from it in ten minutes.

## THE POA&M — WHAT MAY WAIT, AND WHAT MAY NOT

A POA&M is a short leash, not a parking lot.

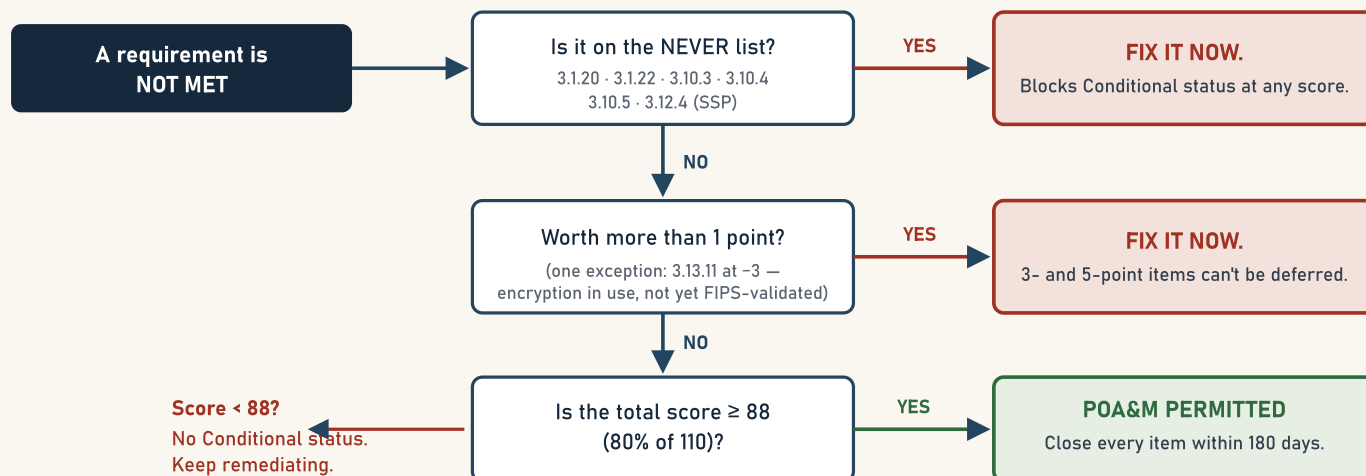


Figure 5 — The POA&M eligibility gate (32 CFR 170.21). All three checks must pass — for every open item at once.

### THE 180-DAY CLOCK

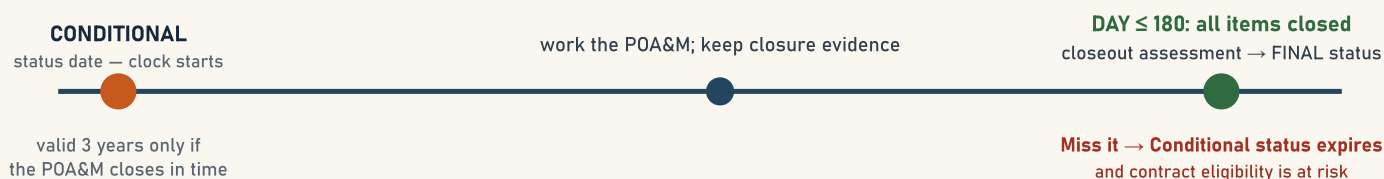


Figure 6 — Conditional → Final. The POA&M closeout (self-assessment or C3PAO, matching your assessment type) must confirm every item within 180 days.

#### ▲ WATCH OUT — A POA&M DOES NOT MAKE A CONTROL MET

An item on the POA&M is still NOT MET and still costs its points. The POA&M only buys time — 180 days, once — for a limited class of items. Plan as if the POA&M didn't exist; use it as a shock absorber, not a strategy.

#### ■ TRAIL MARKER — A POA&M ENTRY THAT WOULD SURVIVE REVIEW

**Weak:** "3.3.4 — will configure alerting." **Strong:** "3.3.4 Audit failure alerting — SIEM heartbeat alert to IT manager on log-source silence > 1 hr. Owner: J. Rivera. Milestones: rule built 8/15, tested 8/22, monitored 30 days, close 9/30. Evidence at closure: alert config export + test alert email." Owner, dates, method, and the closure evidence named in advance.

7

# POST TO SPRS AND AFFIRM

The score isn't real until it's in the system — and someone signs their name to it.

SPRS (the Supplier Performance Risk System) is where your self-assessment score, CMMC status, and affirmations live. Contracting officers check it before award. Access runs through PIEE (piee.eb.mil) — set up your account early; registration is its own small project. One clarification: for **Level 2 (Self)** you enter the assessment results yourself; for a **C3PAO certification**, the assessment results are submitted from the C3PAO's side (through the CMMC instance of eMASS, which feeds SPRS) — your own required act in SPRS is the **affirmation**.

## HAVE READY BEFORE YOU LOG IN

| FIELD                        | NOTES                                                                                        |
|------------------------------|----------------------------------------------------------------------------------------------|
| CMMC level & assessment type | Level 2 (Self) or Level 2 (C3PAO) — whichever your contracts require.                        |
| CMMC Status Date             | The date your assessment completed — starts the 3-year validity and any 180-day POA&M clock. |
| Assessment scope description | Matches the SSP boundary — enclave or enterprise.                                            |
| CAGE code(s)                 | Every CAGE covered by the systems in scope.                                                  |
| Score (e.g., 103 / 110)      | From your worksheet; keep the worksheet.                                                     |
| POA&M status                 | Whether one exists and is compliant with the eligibility rules.                              |
| Affirming Official           | Name, title, contact — a senior official who can bind the company.                           |

▲ WATCH OUT — THE AFFIRMATION IS A LEGAL ACT, NOT A CHECKBOX

The Affirming Official attests that the company has implemented — and will maintain — the requirements, and re-affirms **every year**. A knowingly false submission is the kind of statement the Department of Justice has pursued under the False Claims Act. Never let anyone sign it who hasn't seen the evidence. And calendar the annual affirmation: letting it lapse invalidates your status.

✓ PROVE IT

Save the SPRS submission confirmation, the scoring worksheet behind the number, and a dated record of what the Affirming Official reviewed. Six years is the artifact-retention expectation — file it like you'll need it in year five.

## ASSESSMENT WEEK — THE C3PAO VISIT

What actually happens when the assessors arrive, and how to make it boring (boring is good).

Most contracts with CUI will require certification by a **C3PAO** — an assessment organization authorized by the Cyber AB. You hire them directly (get quotes early; good ones book out months ahead). The assessment follows the CMMC Assessment Process in four broad phases:

| PHASE                             | WHAT HAPPENS · WHAT THEY'LL WANT FROM YOU                                                                                                                                                                                                                                                                                                             |
|-----------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>1 · Plan &amp; prepare</b>     | Contracting, scope validation, readiness check, evidence logistics. They review your SSP, diagram, and asset inventory <i>before</i> arriving. A weak scoping pack stalls everything here.                                                                                                                                                            |
| <b>2 · Conduct the assessment</b> | Days of examine / interview / test across the 110 requirements and their objectives. Expect screen-sharing sessions ("show me the live setting"), staff interviews, and walk-throughs of the facility.                                                                                                                                                |
| <b>3 · Report results</b>         | Findings are scored MET / NOT MET / N/A; results are briefed to you and recorded. Narrowly-scoped deficiencies may be correctable within a short window during the process — ask your C3PAO how they handle deficiency correction. Outcome: Final status (all met), Conditional status (score ≥ 88 and only POA&M-eligible items open), or no status. |
| <b>4 · POA&amp;M close-out</b>    | If Conditional: fix every POA&M item, then a close-out assessment confirms closure within 180 days → Final.                                                                                                                                                                                                                                           |

### THE THREE WAYS THEY VERIFY EVERYTHING

| METHOD           | WHAT IT LOOKS LIKE                                                                                              | YOUR PREPARATION                                                               |
|------------------|-----------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------|
| <b>Examine</b>   | "Show me the policy... the config... the log... the ticket."                                                    | The evidence binder, organized by family, findable in seconds.                 |
| <b>Interview</b> | "How do you handle a departing employee?" — asked of the person who actually does it.                           | Staff who can describe their piece in their own words. Not scripts — practice. |
| <b>Test</b>      | "Log in as a normal user and try to reach the admin console." "Plug in this concept — what blocks a USB drive?" | Controls that hold up when poked, not just when screenshotted.                 |

#### ▲ WATCH OUT — INTERVIEWS ARE NOT JUST FOR IT

Assessors interview the people who *perform* the work: the office manager about visitor escorts, HR about offboarding, an engineer about handling drawings, the receptionist about the sign-in sheet. A classic interview failure isn't a wrong answer — it's "I didn't know we had a policy about that." Brief everyone; the employee card at the back of this guide exists for exactly this week.



#### ✓ AN ASSESSMENT THAT GOES SMOOTHLY

- One coordinator owns logistics; evidence indexed per requirement in advance.
- Every claim in the SSP has a matching artifact — no "let me find that."
- Staff answer from experience: "I lock the screen, I escort visitors, I report weird emails to Sam."
- Something small is NOT MET and you say so, with the fix in motion. Honesty reads as maturity.

#### ✗ AN ASSESSMENT THAT UNRAVELS

- The SSP describes a company that doesn't exist ("we review logs daily" — last review: never).
- Evidence generated the week before, all timestamped the same day.
- Employees visibly hearing about policies for the first time.
- Arguing every finding. Assessors document what they observe; the fix is fixing, not debating.

### AFTER YOU PASS: THE THREE-YEAR RHYTHM

- **Annually:** the Affirming Official re-affirms in SPRS. Miss it and the status lapses.
- **Continuously:** keep evidence flowing (log reviews, training, scans, access reviews). New systems, clouds, or offices go into the SSP *when they change*, not in year three.
- **Year 3:** full reassessment. If evidence stayed alive, prep is weeks, not a year.
- **Six years:** keep assessment artifacts that long from each Status Date.

## EVIDENCE THAT SURVIVES AN ASSESSOR

Every waypoint ends at the same door: **can you show it?** Here is the difference, six times, between evidence that holds and evidence that folds.

### ✓ HOLDS UP

- **MFA:** identity-provider policy export showing MFA enforced for all users, dated this quarter + enrollment report (23/23 users) + the sign-in log of a real MFA prompt.
- **Screen lock:** the GPO/MDM setting (15 min) + policy citing 15 min + a photo of a locked, pattern-hidden screen.
- **Offboarding:** HR ticket 4482: separation 3:10 p.m., accounts disabled 3:25 p.m., badge returned, checklist signed.

### ✗ FOLDS

- **MFA:** "Everyone has MFA" (spoken); a screenshot with no tenant name, no date, taken who-knows-when; three service accounts quietly exempted and unmentioned.
- **Screen lock:** policy says 15 minutes; the live setting says "never." (Now *two* findings: the control and the false document.)
- **Offboarding:** "IT usually disables accounts pretty fast." No ticket. Assessor pulls the account list: two ex-employees still enabled.

### ✓ HOLDS UP

- **Log review:** a recurring calendar entry + a one-paragraph review note each week ("reviewed auth failures, 2 lockouts, benign, JR 6/12") — twelve of them in a row.
- **Training:** LMS report: all staff, completion dates, this year's content attached; new-hire completions within first week.
- **FIPS:** the CMVP certificate number for each crypto module recorded next to the system using it.

### ✗ FOLDS

- **Log review:** "We look at logs when something seems off." Zero records. A control nobody can see happening isn't happening.
- **Training:** one undated sign-in sheet from two years ago; three current employees not on it.
- **FIPS:** "It uses AES-256, so it's FIPS." Validation is about the *tested module*, not the algorithm name.

### ■ TRAIL MARKER — THE FRESHNESS TEST

Strong evidence accumulates on a rhythm: dated, named, and boring. If your entire binder was created in one heroic week, an assessor will notice the timestamps — and so will you, at 2 a.m., during that week. The cheapest evidence program is a calendar: every recurring control (reviews, scans, training, access recerts) gets a recurring slot and a one-paragraph record. Fifteen minutes a week beats a forensic reconstruction every three years.

## TEN WAYS GOOD TEAMS GET HURT

| #  | THE HAZARD                                                                                                | THE COUNTER-MOVE                                                                                                   |
|----|-----------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------|
| 1  | <b>Scoping everything</b> — the flat network goes to assessment.                                          | Build the enclave. Shrink the bubble before you gold-plate it.                                                     |
| 2  | <b>The stale or missing SSP</b> — the one item with no points and total power.                            | Treat the SSP as a living document with an owner and an update trigger list.                                       |
| 3  | <b>Draft-itis</b> — policies stuck at "DRAFT v0.9" for a year.                                            | Sign them. An imperfect signed policy beats a perfect draft.                                                       |
| 4  | <b>MFA gaps</b> — MFA everywhere except the VPN's local admin, the file server, that one service account. | Enumerate every access path to CUI; MFA each one or document the compensating story honestly.                      |
| 5  | <b>"AES means FIPS"</b> — assuming algorithm = validation.                                                | Record CMVP certificate numbers per module. If it isn't validated, say so and take the -3 with a plan.             |
| 6  | <b>Consumer cloud drift</b> — CUI in a personal-tier file share or free email.                            | CUI clouds need FedRAMP Moderate or equivalency. Migrate before, not after, it's noticed.                          |
| 7  | <b>Invisible periodic controls</b> — reviews and scans that "happen" but leave no residue.                | Calendar + one-paragraph record, every time. No record, no control.                                                |
| 8  | <b>POA&amp;M as a wish list</b> — 5-pointers parked with hopeful dates.                                   | Only 1-point items (plus the single 3.13.11 exception) may sit there — and only at a score of 88 or higher.        |
| 9  | <b>The 88 finish-line myth</b> — celebrating the score while ineligible items sit open.                   | Run the three-question gate (Figure 5) on every open item, not just the total.                                     |
| 10 | <b>The casual affirmation</b> — signing SPRS without reading the evidence.                                | Give the Affirming Official a one-hour evidence walkthrough before every affirmation. Their signature, their risk. |

#### ■ TRAIL MARKER — THE MSP COROLLARY

Half these hazards hide inside "our IT provider handles it." Your MSP can operate controls, but **you** own the requirement, the evidence, and the affirmation. Get the shared responsibility matrix in writing, get read access to the consoles that prove your own controls, and make the MSP's remote-access path meet the same rules (MFA, logging, managed access points) as everyone else's.

# THE EMPLOYEE CARD — SIX RULES THAT CARRY THE WHOLE COMPANY

You don't need to know 110 requirements. If every person does these six things, most of the human side of CMMC takes care of itself.

| RULE                                   | WHAT IT MEANS FOR YOU                                                                                                                                                                                                                                 |
|----------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>1 • Know what CUI looks like</b>    | Marked documents (CUI banner), technical drawings, anything the government or the prime says is controlled. Not sure? Ask before you share, print, or forward.                                                                                        |
| <b>2 • Lock your screen</b>            | Every time you stand up. Win + L takes one second.                                                                                                                                                                                                    |
| <b>3 • No mystery USB drives</b>       | Found a thumb drive? Don't plug it in — hand it to IT. Personal drives stay out of work machines.                                                                                                                                                     |
| <b>4 • Escort your visitors</b>        | Sign them in, badge them, stay with them. A friendly stranger walking the hall alone is everyone's problem.                                                                                                                                           |
| <b>5 • Report weird things fast</b>    | Odd email, popup, missing laptop, wrong file in the wrong place — tell [your IT/security contact] the same hour. Reporting fast is praised, never punished. Speed matters: the company has as little as 72 hours to report real incidents to the DoD. |
| <b>6 • Keep CUI on company systems</b> | Never to personal email, personal cloud drives, home printers, or group chats. If a tool wasn't issued for CUI, it doesn't get CUI. When in doubt — ask first.                                                                                        |

## ✓ WHY YOU'LL BE ASKED ABOUT THIS

During the assessment, an assessor may ask *you* — not just IT — how you handle visitors, strange emails, or a marked document. "Here's what I do, and here's who I'd call" is a perfect answer. You are the control.

## THE NUMBERS THAT RUN EVERYTHING

### 110

Security requirements in NIST SP 800-171 Rev 2 — and the maximum score.

### 320

Assessment objectives across those requirements. MET means all applicable objectives pass.

### 14

Requirement families, AC through SI.

### 5-3-1

Point weights: 44 fives, 14 threes, 51 ones, plus the unscored SSP. Floor: –203.

### 88

Minimum score (80% of 110) for Conditional status — necessary, never sufficient by itself.

### 6

Requirements that can never sit on a POA&M: 3.1.20, 3.1.22, 3.10.3, 3.10.4, 3.10.5, 3.12.4.

### 180

Days from the Conditional Status Date to close every POA&M item — or the status expires.

### 3 yrs

Validity of a Level 2 status — with an affirmation renewed every year in SPRS.

### 6 yrs

How long to retain assessment artifacts from each CMMC Status Date.

### 72 hrs

DFARS 252.204-7012 deadline to report cyber incidents to DoD via DIBNet.

### 15

Requirements at Level 1 (FCI only, FAR 52.204-21) — annual self-assessment.

### 2

Partial-credit requirements: 3.5.3 (MFA) and 3.13.11 (FIPS crypto) — the only ones.

## GLOSSARY — PLAIN DEFINITIONS

**Affirming Official** — the senior person who attests in SPRS, annually, that requirements are implemented and maintained.

**C3PAO** — CMMC Third-Party Assessment Organization; authorized by the Cyber AB to perform Level 2 certification assessments.

**CAGE code** — Commercial and Government Entity code identifying your company in federal systems.

**CMMC** — Cybersecurity Maturity Model Certification, the DoD program (32 CFR Part 170) verifying contractor cybersecurity.

**CMVP** — NIST's Cryptographic Module Validation Program; its certificate list defines "FIPS-validated."

**Conditional / Final status** — Conditional: assessed with a compliant POA&M open (score ≥ 88). Final: everything met (or POA&M closed within 180 days).

**CUI** — Controlled Unclassified Information; unclassified information requiring safeguarding under law, regulation, or

government-wide policy. Cataloged in the NARA CUI Registry.

**Cyber AB** — the CMMC accreditation body; authorizes C3PAOs and runs the assessor ecosystem.

**DIBCAC** — DCMA's Defense Industrial Base Cybersecurity Assessment Center; conducts government-led assessments, including Level 3.

**DIBNet** — the DoD portal ([dibnet.dod.mil](https://dibnet.dod.mil)) for mandatory cyber-incident reporting.

**Enclave** — a deliberately fenced-off environment where CUI lives, keeping the rest of the company out of scope.

**ESP** — External Service Provider (cloud vendors, MSPs/MSSPs) that handles CUI or provides security for it; part of your assessment story.

**FCI** — Federal Contract Information; non-public contract information. Protected at Level 1.

**FedRAMP Moderate** — the federal cloud security baseline required (or equivalency) for clouds holding CUI under DFARS 7012.

**FIPS-validated** — cryptography whose specific module passed CMVP testing; required when encryption protects CUI confidentiality.

**MET / NOT MET / N/A** — the three assessment findings per requirement; N/A needs a scope-based justification and doesn't cost points.

**OSA / OSC** — Organization Seeking Assessment / Certification. You.

**POA&M** — Plan of Action & Milestones; the tightly limited list of open items being fixed on a deadline.

**SPRS** — Supplier Performance Risk System; where scores, statuses, and affirmations are recorded and checked.

**SSP** — System Security Plan; the master description of your system, boundary, and how every requirement is implemented.

# SOURCES, AND HOW TO VERIFY THIS GUIDE

Every rule in this guide traces to one of the documents below. When you make a real decision — a bid, an SPRS entry, a C3PAO engagement — verify against the current official version, not this guide and not any secondhand source.

| SOURCE                                                              | WHAT IT GOVERNS                                                                                                                                  |
|---------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>32 CFR Part 170</b> (the CMMC Program rule) — esp. §§ 170.16–.24 | Levels, assessment types, Conditional/Final status, POA&M limits and the 180-day clock, affirmations, artifact retention, scoring incorporation. |
| <b>NIST SP 800-171 Rev 2</b>                                        | The 110 security requirements themselves.                                                                                                        |
| <b>NIST SP 800-171A</b>                                             | The 320 assessment objectives and examine/interview/test methods.                                                                                |
| <b>DoD NIST SP 800-171 Assessment Methodology, v1.2.1, Annex A</b>  | The 5/3/1 point weights, the two partial-credit rules, the –203 floor, and the SSP's special unscored treatment.                                 |
| <b>CMMC Assessment Guide — Level 2, v2.13 (Sep 2024)</b>            | How assessors evaluate each requirement and objective; MET/NOT MET criteria.                                                                     |
| <b>CMMC Scoping Guide — Level 2, v2.13</b>                          | The five asset categories and boundary rules.                                                                                                    |
| <b>DFARS 252.204-7012 / -7019 / -7020 / -7021</b>                   | Safeguarding, 72-hour incident reporting, FedRAMP Moderate for clouds, SPRS posting, and the contractual CMMC requirement.                       |
| <b>FAR 52.204-21</b>                                                | The 15 basic safeguarding requirements (Level 1).                                                                                                |
| <b>SPRS entry tutorials / PIEE documentation</b>                    | The mechanics of posting scores and affirmations.                                                                                                |
| <b>NARA CUI Registry · NIST CMVP · NIST SP 800-88</b>               | CUI categories and markings · FIPS-validated module certificates · media sanitization.                                                           |

Find the official documents at the DoD CIO's CMMC documentation page, [csrc.nist.gov](https://csrc.nist.gov), [ecfr.gov](https://ecfr.gov), and [sprs.csd.disa.mil](https://sprs.csd.disa.mil). Regulations change: re-check the sources (and whether a newer 800-171 revision applies to your contracts) before any high-stakes decision.

X FINAL HONESTY BOX

This guide is a plain-language learning and preparation aid for small defense contractors. It was prepared by Chris Judkins with AI assistance against the sources above and reviewed for accuracy, but it is **not** legal advice, is **not** an official DoD, NIST, or Cyber AB publication, and **confers no CMMC status**. Assessment outcomes depend on your implementation and your assessor's findings — no guide can promise a result. For decisions that carry contract or legal weight, engage a qualified CMMC professional (a CCP/CCA or a Registered Practitioner Organization) and rely on the official documents. CMMC® and Cybersecurity Maturity Model Certification are marks of the U.S. Department of Defense; this guide is independent and unaffiliated.

The CMMC Level 2 Survival Guide · Plain-English Edition · July 2026 · Prepared by Chris Judkins · Companion to **CMMC Vault**, the open-source, session-only readiness scoring tool this guide ships with ([github.com/CJud25/CMMCVault](https://github.com/CJud25/CMMCVault)). Use the app to score yourself and find what blocks eligibility; use this guide to understand the trail.